Continental
The Future in Motion

AUTOSAR Security Overview

Florin Anton

Heat SWT

About me

- Senior SW engineer
- Automotive Security enthusiast since 2020
- Interests: AUTOSAR Security, Security concepts
- Active member in the AUTOSAR Workgroup Security since 2020 (AP & CP)
- Speaker of Workgroup Security Classic Platform since 2022
- Leading a team of developers that handle AUTOSAR coding activities for the APD
- Security Techboard coordinator

Internal

he[a]t Architecture & Software
Enabling Software Development Excellence

Agenda

1. Introduction and History
2. AUTOSAR Consortium / AUTOSAR Classic vs AUTOSAR Adaptive
3. AUTOSAR Security Concepts
4. Current trends & Future concepts
5. UNECE

Internal

Introduction and History

Introduction and history

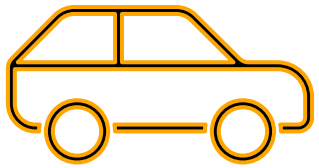
History of E/E architecture

50s
All-mechanic car

80s/90s
Beginning of contemporary E/E architecture (e.g. CAN-Bus)

2000s/2010s
Increasing number of ECUs

Today
Connected Vehicle requires new E/E architecture



2002
Foundation of AUTOSAR – Standardizing the E/E architecture

Around 2010
AUTOSAR becomes the go-to Middleware for automotive ECUs

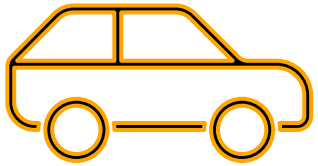
2018
Adaptive AUTOSAR is released – supporting new E/E architectures

Introduction and history

Brief history of automotive security

90s
R&D on auto-motive security

2010s
Prominent hacks (e.g. Jeep hack)
Stronger focus on security

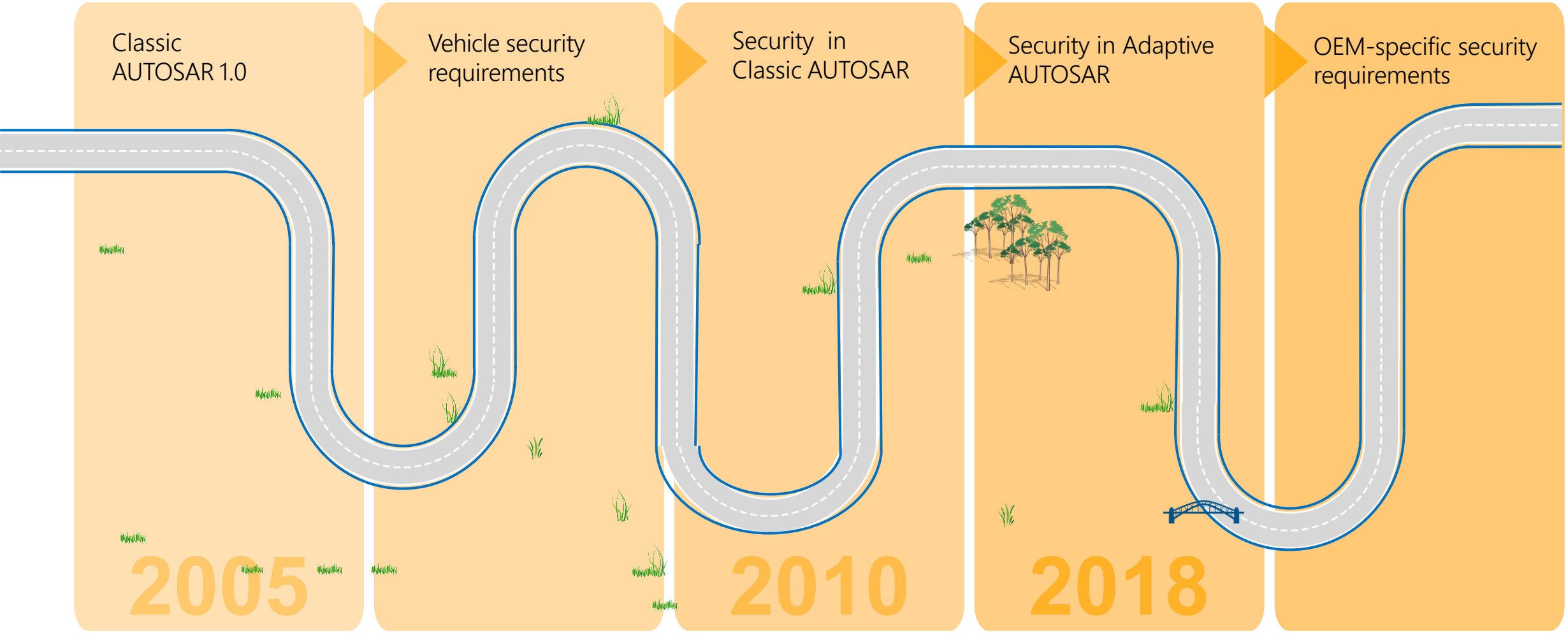


90s
First electronic immobilizers

2000s
More and more security use-cases (e.g. component theft protection)

2010s
Security of the connected car

AUTOSAR Cybersecurity Road



Continental

Florin Anton © Continental AG

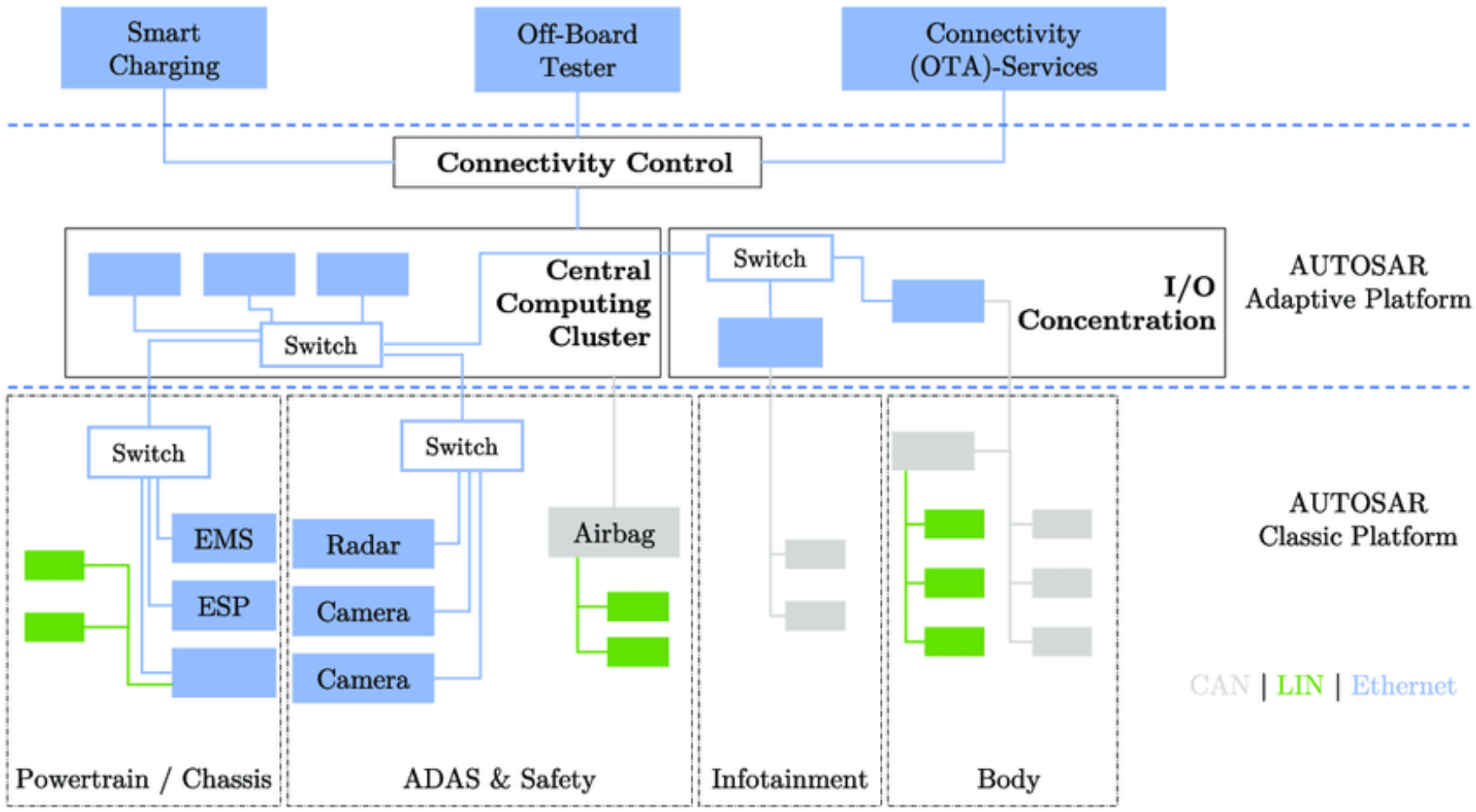
Internal

AUTOSAR Consortium / AUTOSAR Classic vs AUTOSAR Adaptive

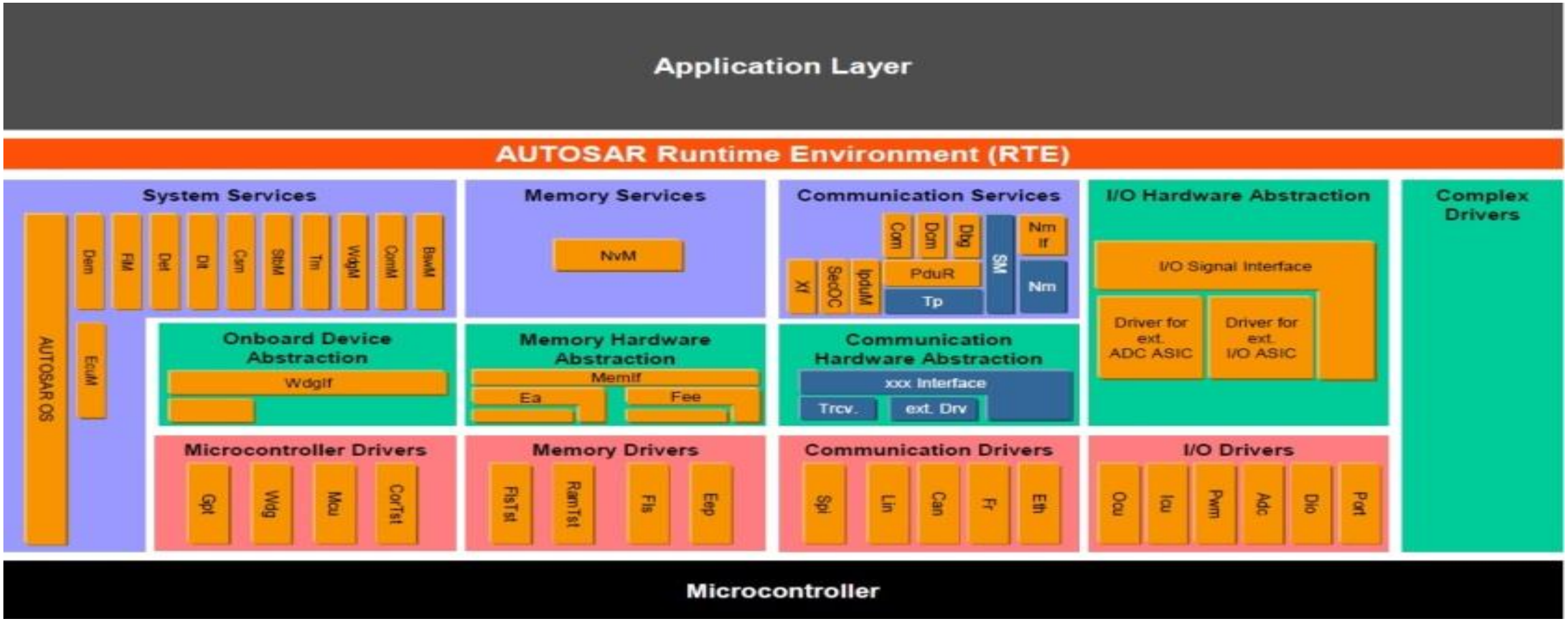
AUTOSAR Consortium

Source: AUTOSAR

AUTOSAR Classic / AUTOSAR Adaptive

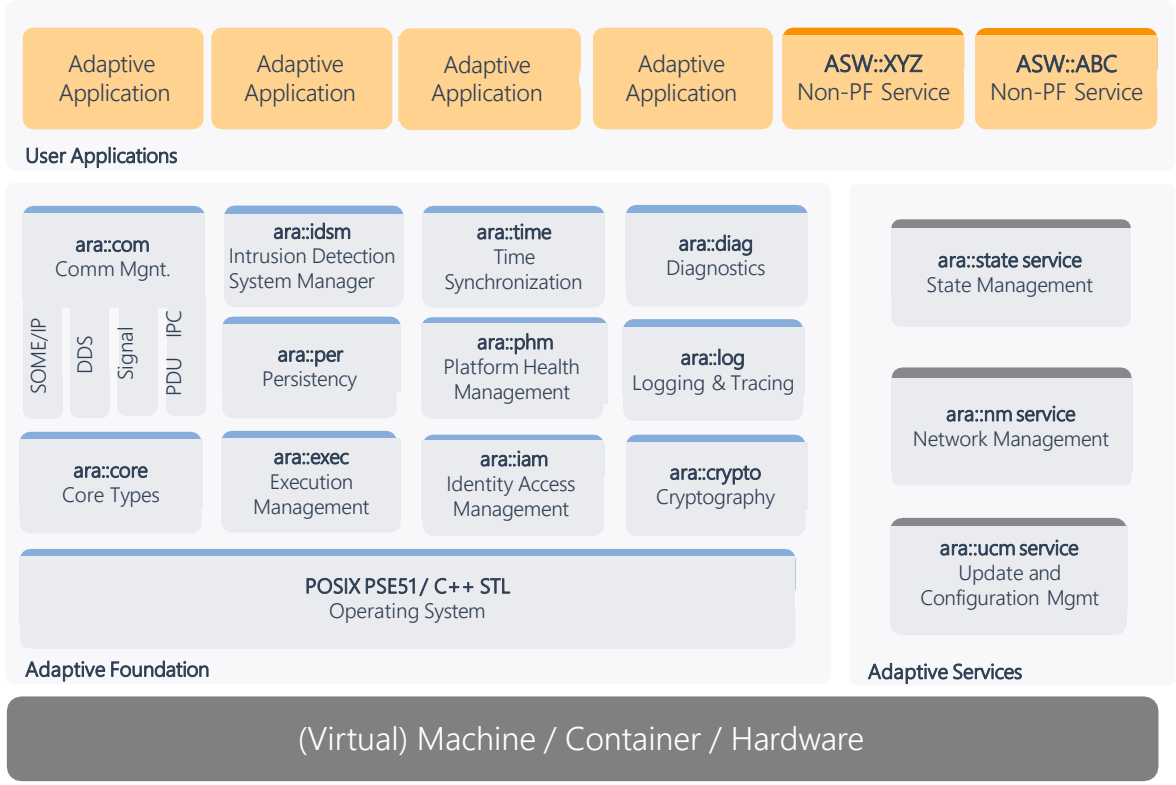


Classic AUTOSAR



- Layered software architecture
- Code can be executed directly from flash
- Static memory layout defined at compile time
- No memory isolation of applications

Adaptive AUTOSAR



- Based on POSIX-compatible OS (e.g. Linux)
- Functional clusters (ara::com, ara::crypto, .)
- Code dynamically loaded to RAM
- Dynamic memory allocation during runtime
- Applications executed/isolated within processes

➔ Both platforms have fundamentally different architectures.
➔ Some security controls are hence only applicable to one of the two platforms.

AUTOSAR Security Concepts

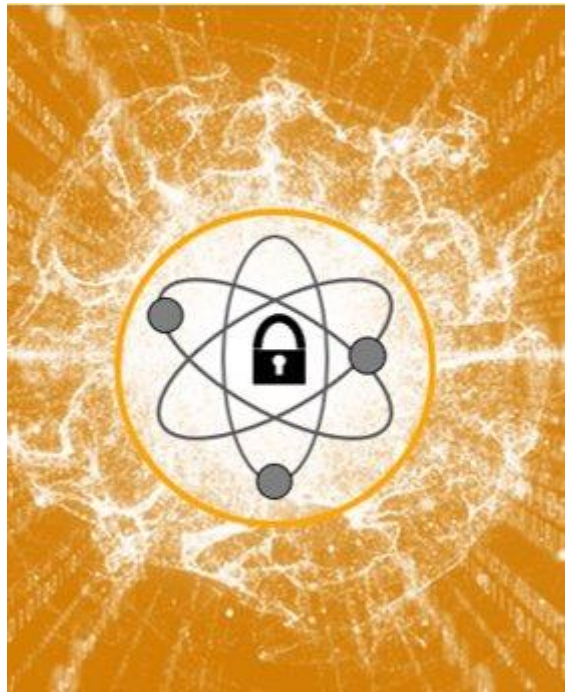
AUTOSAR security concepts

Crypto Stack

An application has to store confidential data (e.g. credit card number for a charging application).

This data has to be encrypted to prohibit unauthorized access.

- AUTOSAR Crypto Stack provides access to cryptographic primitives
- Support for multiple crypto libraries/Hardware Security Modules
- Classic & Adaptive AUTOSAR

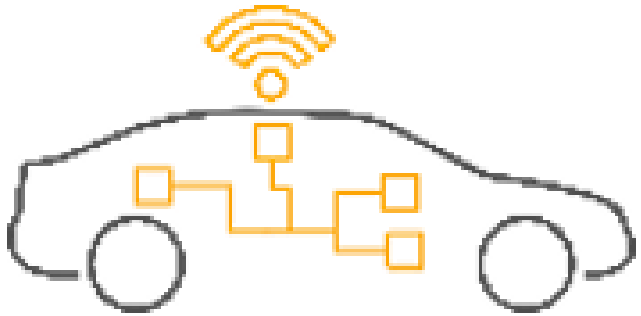


AUTOSAR security concepts

Secure Communication

Securing the in-vehicle network

Example: Authentic broadcast of unlock-doors message as part of anti-theft system



Securing the connection to backend services

Example: Secure access to OEM backend services

SecOC

AUTOSAR proprietary protocol for authentic onboard communication

✔ Classic AR ✔ Adaptive AR

TLS

Well-established security protocol on Transport Layer

✔ Classic AR ✔ Adaptive AR

IPSec

Well-established security protocol on Network Layer

✔ Classic AR ✔ Adaptive AR

AUTOSAR security concepts

Secure Diagnostic Access

Example

Critical data (e.g. immobilizer status data) has to be made accessible via diagnostic services, e.g. for problem solving support

This data can give attackers additional insight and must be protected from unauthorized access.

Secure Diagnostic Access

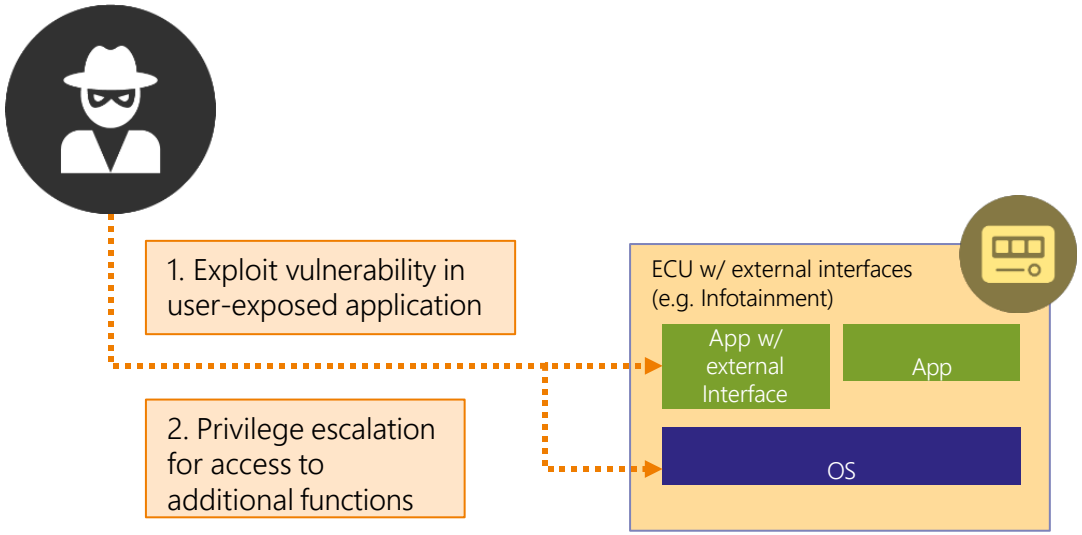
Diagnostic Tester authentication and authorization

✔ Classic AR ✔ Adaptive AR

UDS Services

- 0x27 Security Access: Challenge-Response
- 0x29 Authentication: Challenge-Response & Certificate-based

AUTOSAR security concepts

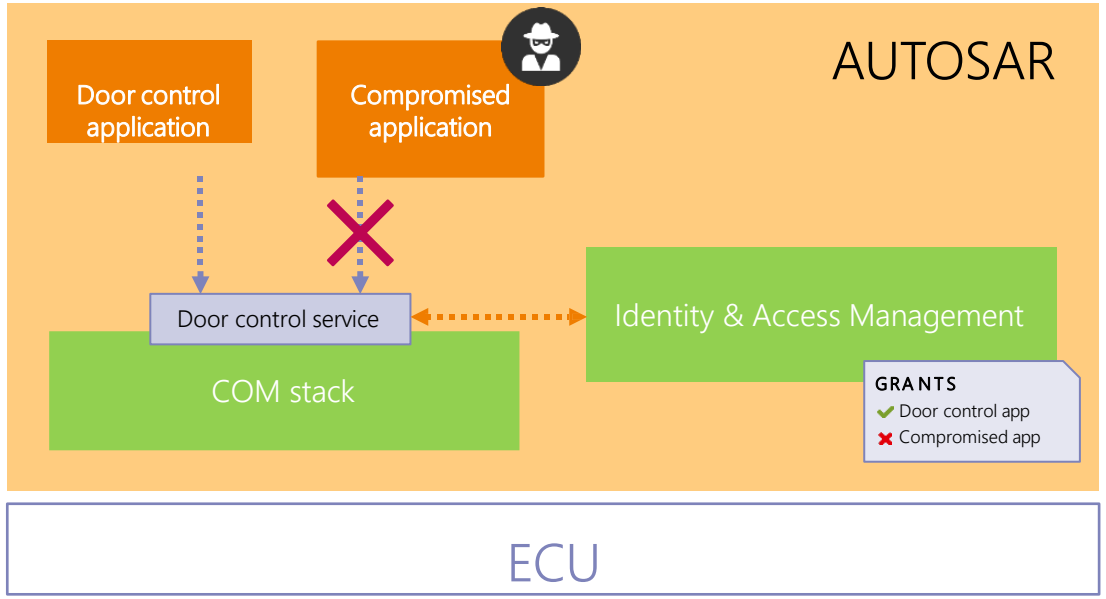


Proposed measures

- Ensure code integrity
  - Secure Boot/**Trusted Platform (A)**
- Fine-grained access control
  - OS-specific tools like SELinux, AppArmor, .
  - **Identity & Access Management (A)**
- Application isolation
  - Separate User-IDs, containerization, sandboxing .
  - Not standardized in AR, strongly dependent on concrete implementation

AUTOSAR security concepts

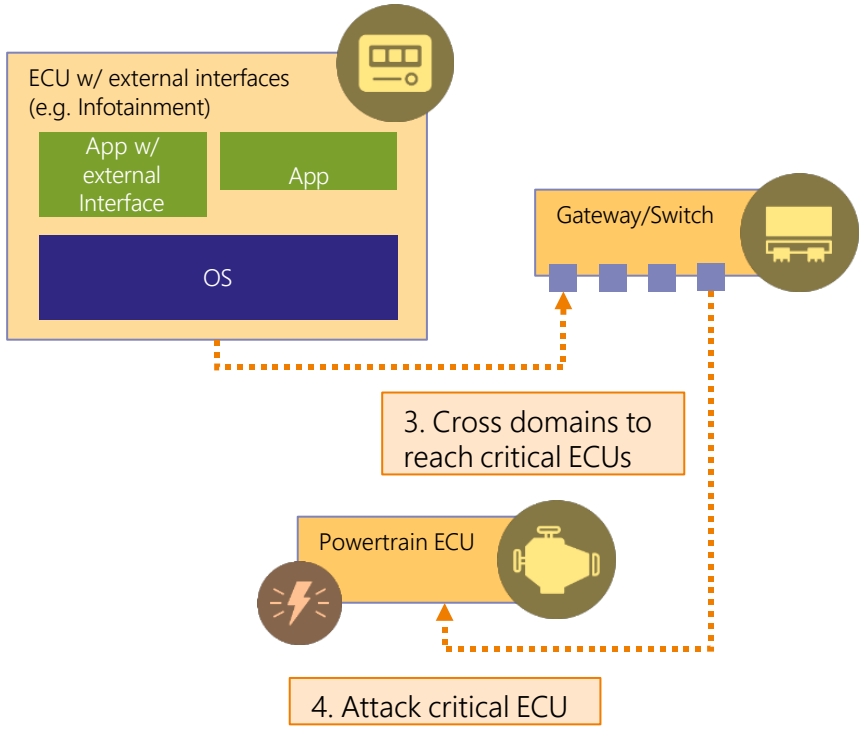
Identity & Access Management (IAM)



Identity & Access Management (IAM)

- Applications are deployed together with corresponding (signed) access rights (grants)
- IAM manages these grants and authorizes applications to access specific services
- Works with local applications and remote ECUs
  - Local applications can be identified by the respective process
  - Remote ECUs can be authenticated using TLS/IPsec or by trusting the network

AUTOSAR security concepts



Proposed measures

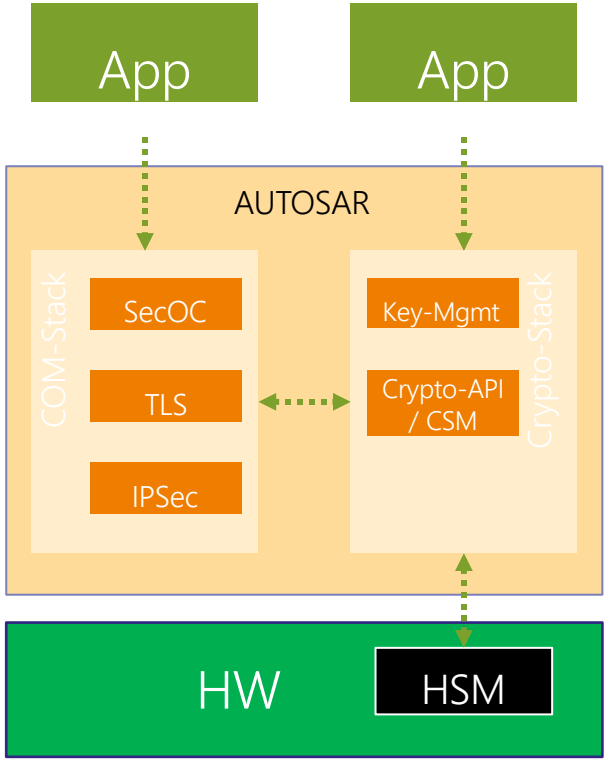
- Domain separation
  - Group ECUs with similar use-cases/criticality on the same physical bus/VLAN
  - Reduce the amount of cross-domain communication as much as possible
  - Enforce domain separation e.g. by a network firewall
- ECU authentication
  - Prevent spoofing of ECUs by authenticating in-vehicle traffic
  - AUTOSAR-supported protocols: SecOC, TLS, IPsec (C/A)

AUTOSAR security concepts

SecOC, CSM

Secure communication

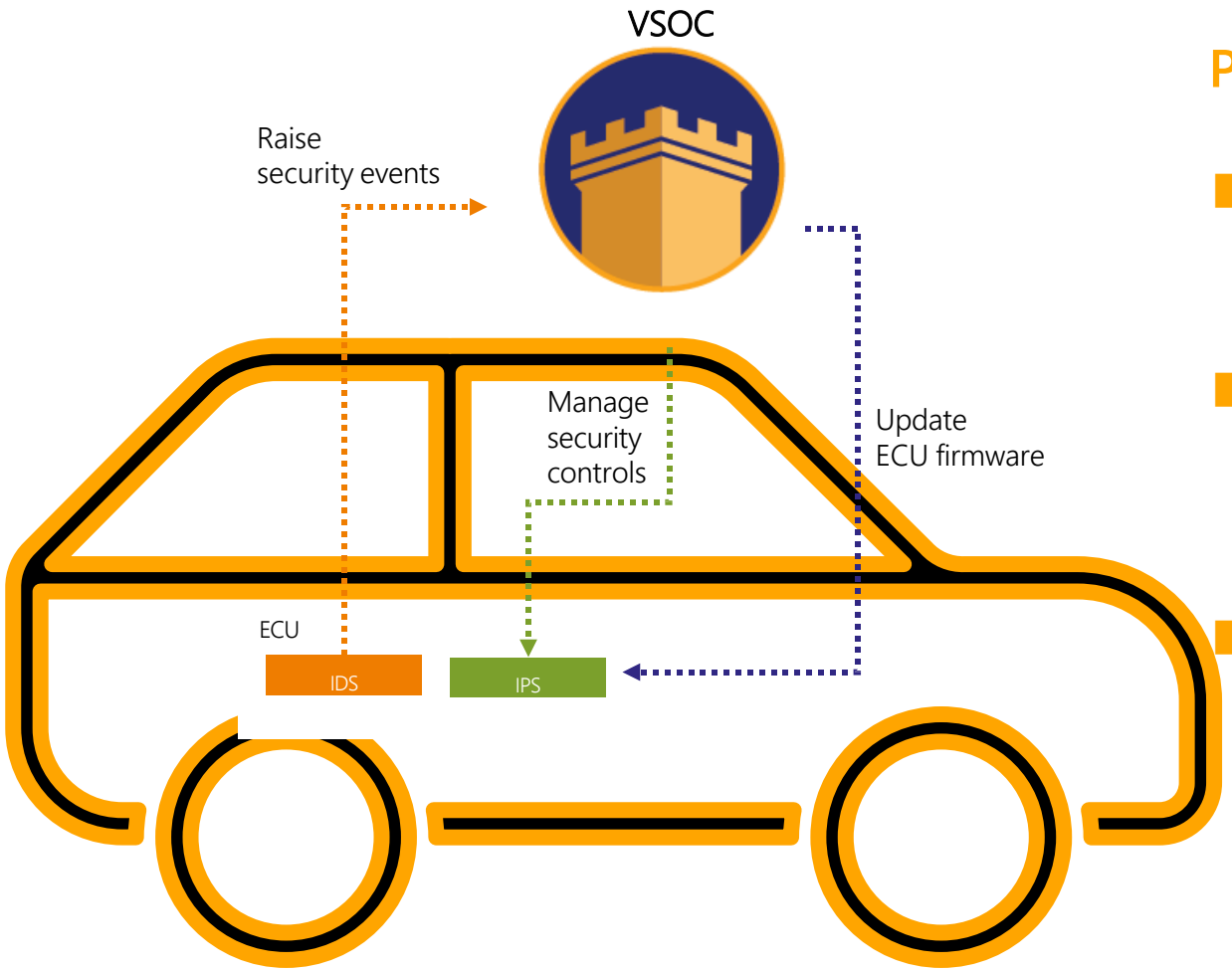
- Supported protocols
  - SecOC (CAN, FlexRay, (tKernet, .)
  - TLS (Ethernet)
  - IPsec (Ethernet)
- Secure communication configuration in AUTOSAR stack
  ➔ Transparent for applications



Crypto stack

- Abstracts underlying crypto-implementations & key stores
- Provides key management interfaces
  ➔Essential part of secure communication
- Can also be used by applications, e.g. for data encryption

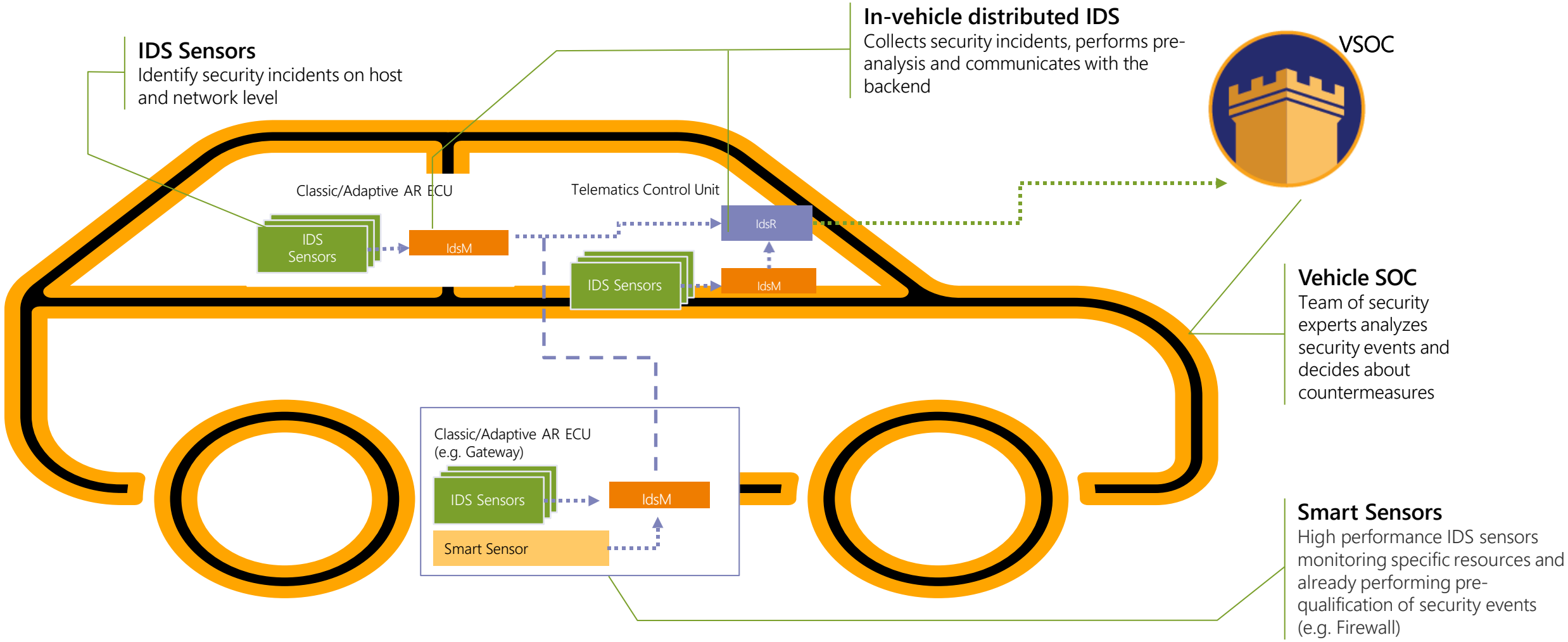
AUTOSAR security concepts



Proposed measures

- Deploy an **Intrusion Detection System (IDS, C/A)**
  to detect ongoing attacks
- Deploy an **Intrusion Prevention System (IPS)** to manage security controls (e.g. firewall rules) to mitigate ongoing attacks
- Provide **SW updates over the air (A)** to fix vulnerabilities

ID(P)S – the immune system for the connected vehicle

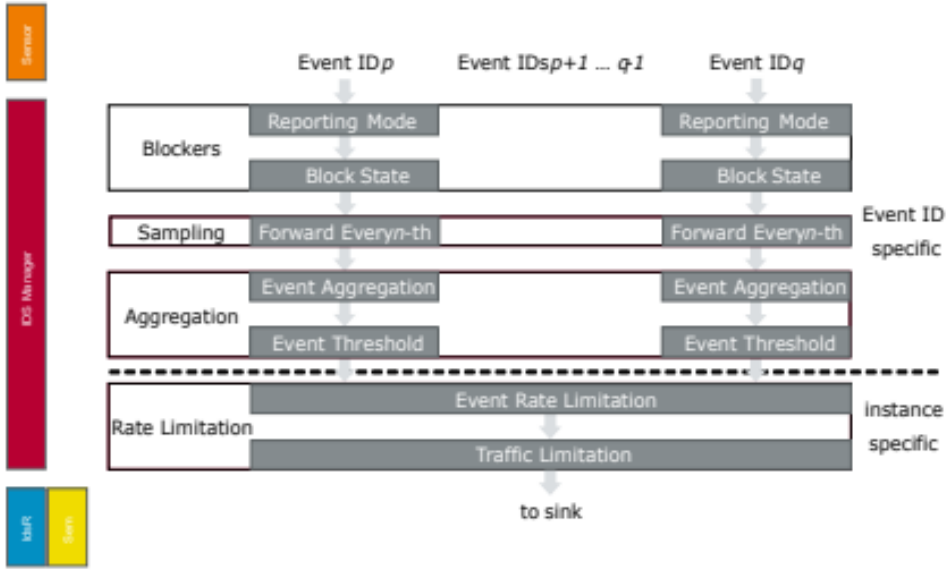


IDSM – the immune system of the connected vehicle

- The IdsM qualifies security events (SEVs) based on a filter chain
  - IdsM generates qualified security events (QSEVs)

- How to handle QSEVs?
  - Store in persistent memory on ECU
  - Send to IdsR for transmission to the VSOC

- QSEV protocol for transmission to IdsR defined within AUTOSAR



AUTOSAR security concepts
Overview of concepts availability

Concept	Classic AR	Adaptive AR
Trusted Platform		X
Crypto Stack	X	X
SecOC	X	X
SecDiag	X	X
IAM		X
IDSM	X	X
Secure Update		X

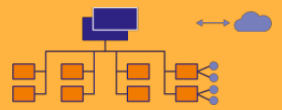
Current architecture trends & Future concepts

Vision

Vehicle-centralized E/E Architecture

- Domain-independent, vehicle-centralized approach with central vehicle computation nodes, neural networks, etc. (zones)
- Logical centralization and physical distribution

Vehicle Cloud Computing



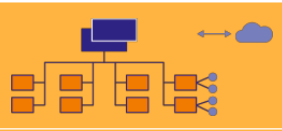
Increasing number of vehicle functions in the cloud

2019-2023

(Cross-) Domain-centralized E/E Architecture

Addresses the complexity of increasing cross-domain and centralized vehicle functions

Vehicle Computer

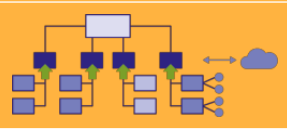


Domain-independent "vehicle computer"

Domain Fusion

Complexity concentration: "cross-domain ECUs"/ "cross domain computation"

Domain Centralization



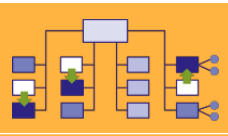
Domain-specific "domain ECUs"/"domain computer"

Today

Distributed E/E Architecture

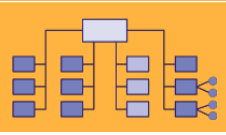
Mostly encapsulated E/E Architecture structure

Integration



Functional integration

Modular



Function-specific ECUs

Increasing software volume

- Domain-specific zone (ECU)
- Performance ECUs, e.g., domain/central/vehicle
- Domain-independent zone ECUs, e.g., door ECU
- State-of-the-art automotive ECUs (function-specific)
- Optional ECUs, e.g., central gateway
- Sensors/actuators

Zone-based EE-architecture

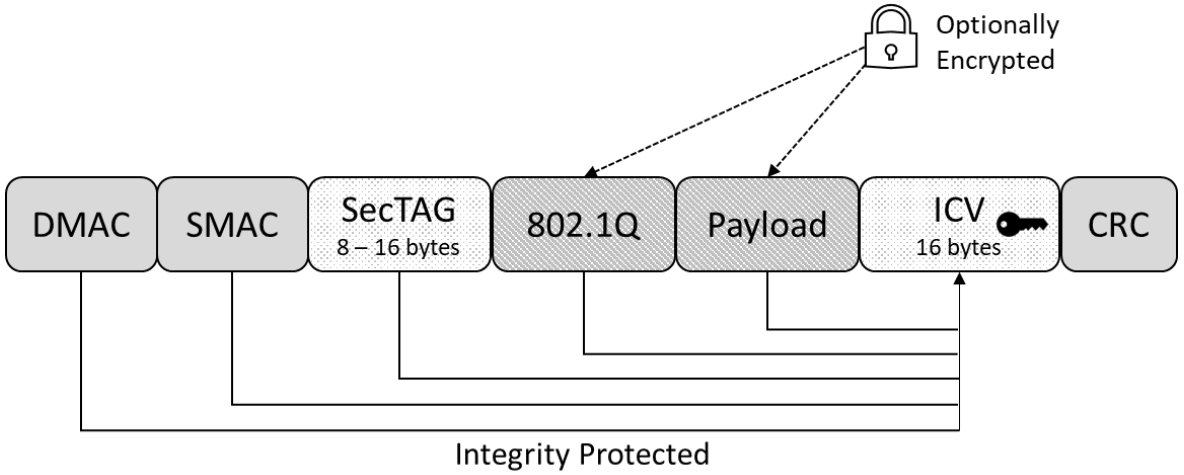
New security controls needed

- MACSec (C/A) for authenticated communication
- Firewall (C/A) for access control

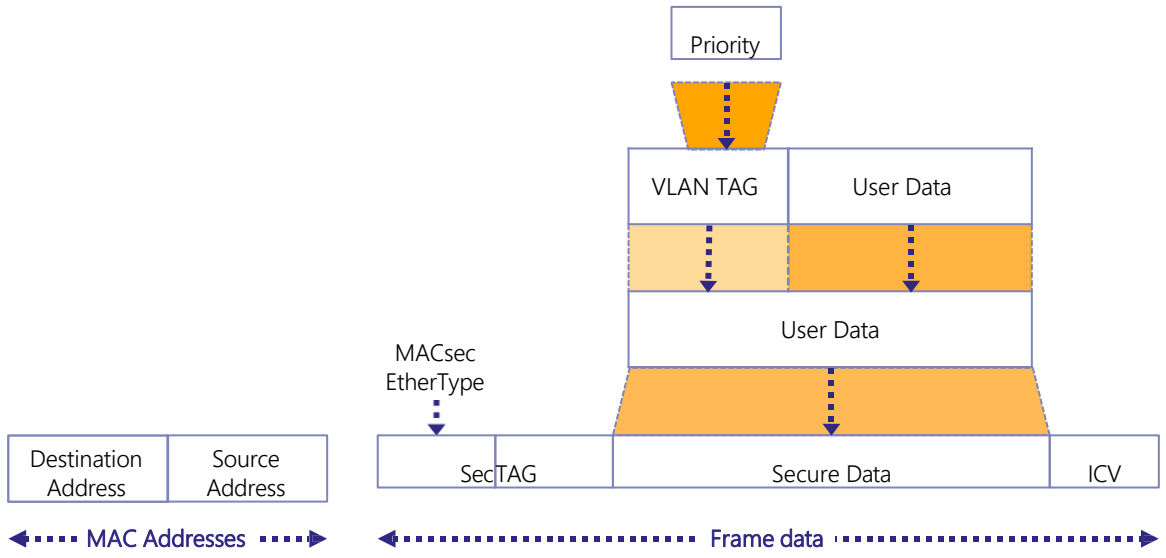
MACSec Introduction

- The 802.1AE standard specifies the implementation of a MAC Security Entities (SecY), which are part of the stations attached to the same LAN, providing secure MAC service to the client. The standard defines:

- MACsec frame format, which is like Ethernet frame, but includes additional fields.
- Security Tag, which is an extension of the EtherType
- Message authentication code (ICV)
- Secure Connectivity Associations that represent groups of stations connected via unidirectional Secure Channels
- Security Associations within each secure channel. Each association uses its own key (SAK). More than one association is permitted within the channel for the purpose of key change without traffic interruption (standard requires devices to support at least two)
- A default cipher suite of GCM-AES-128 (Galois/Counter Mode of Advanced Encryption Standard cipher with 128-bit key)
- GCM-AES-256 using a 256bit key was added to the standard 5 years later.



MACSec



Source: IEEE 802.1AE-20018

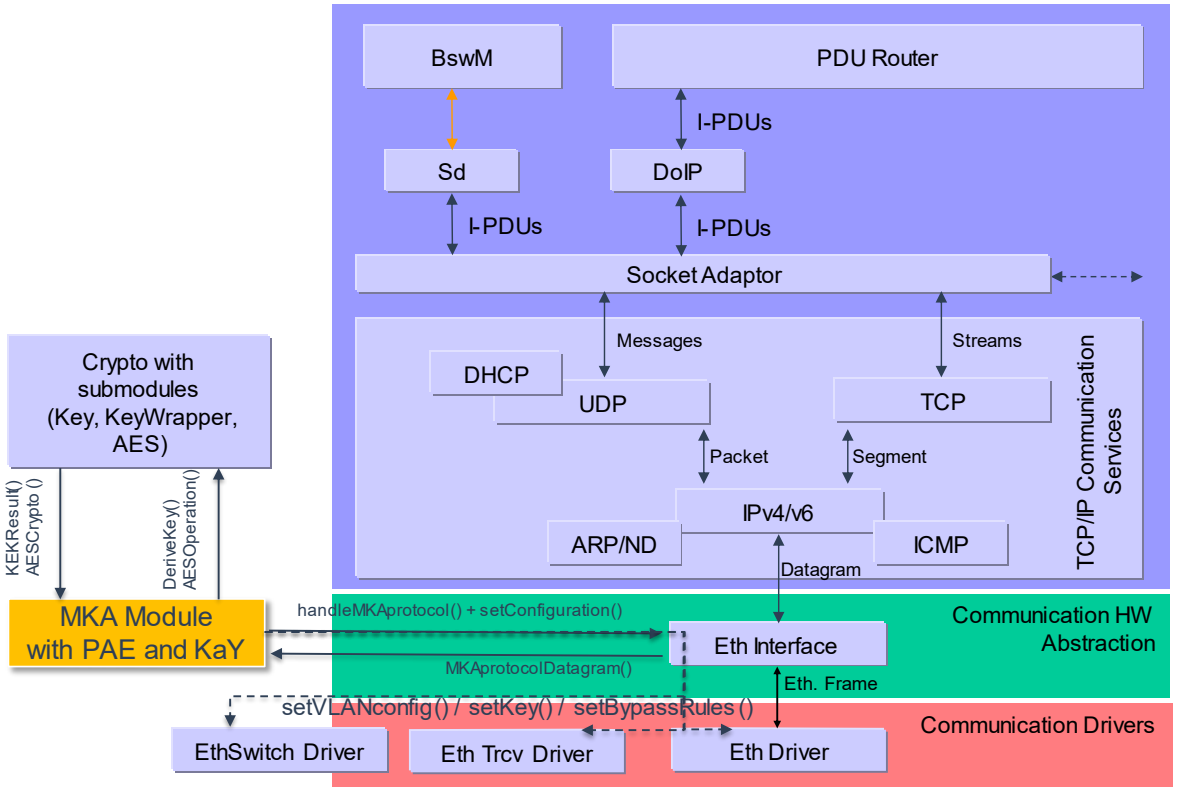
- Secure Ethernet communication on **Data Link Layer** (OSI Layer 2)
- All **higher level protocols** (e.g. IP, TCP) protected by MACSec
- Supports **authentic and confidential communication**
- **No end-to-end security**, only hop-to-hop
- **High bandwidth** possible with HW support

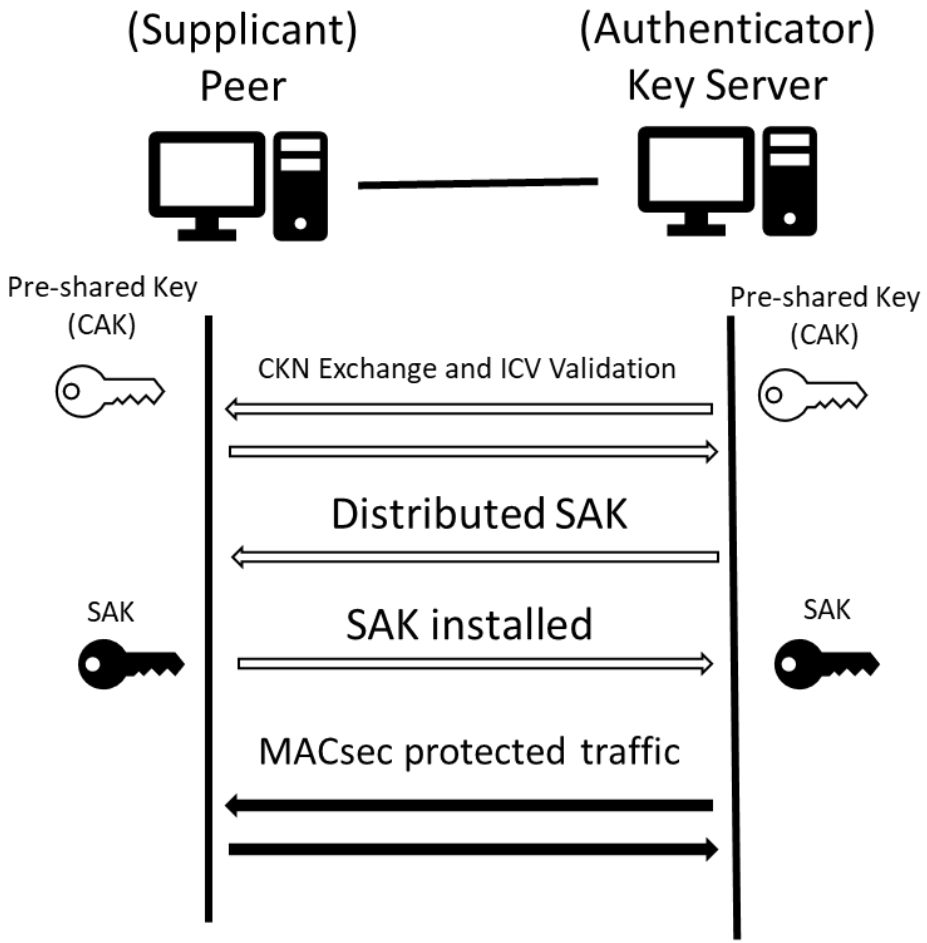
MACSec

Functional Elements

- The MACsec standard defines following functional elements:
- MAC Security Entities (SecYs): Defines and identifies the authentic partners. A SecY implements the secure MAC Service to its clients.
- MACsec Protocol Data Units (MPDU): Defines the frame layout, which resides in the MAC layer (ISO/OSI layer 2).
- MAC Security Key Agreement Entity (KaY): Setup a secure channel via a key agreement and monitors it during its lifecycle.
- Secure Channel Identifier (SCI): Associates a secure channel with an identifier.
- Secure Channel (SC): Stores various configuration parameters, such as whether to perform replay protection, or whether to enable encryption.

MACSec

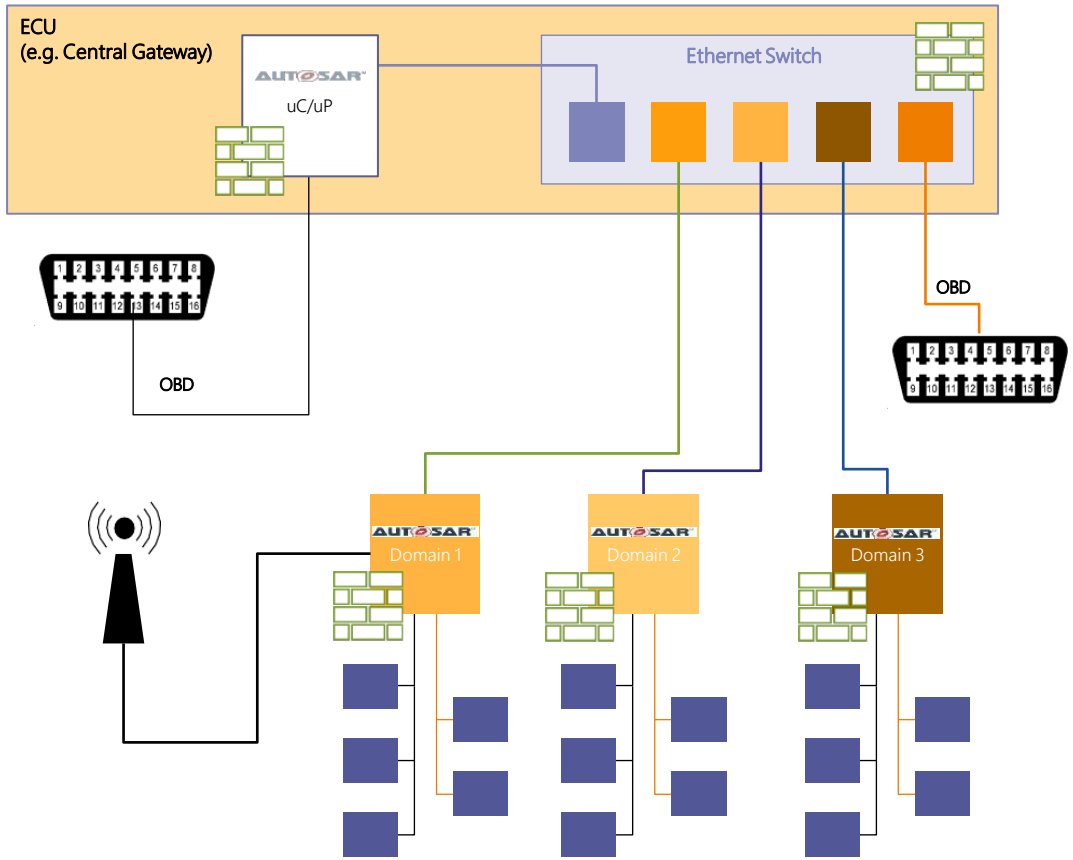

BswM
PDU Router
I-PDUs
Sd
DoIP
I-PDUs
I-PDUs
Socket Adaptor
Messages
Streams
DHCP
UDP
TCP
Packet
Segment
IPv4/v6
ARP/ND
ICMP
Datagram
TCP/IP Communication Services
Crypto with submodules (Key, KeyWrapper, AES)
KEKResult() AESCrypto ()
DeriveKey() AESOperation()
MKA Module with PAE and KaY
handleMKAprotocol() + setConfiguration()
MKAprotocolDatagram()
Eth Interface
Eth. Frame
Communication HW Abstraction
setVLANconfig() / setKey() / setBypassRules ()
EthSwitch Driver
Eth Trcv Driver
Eth Driver
Communication Drivers


(Supplicant) Peer
(Authenticator) Key Server
Pre-shared Key (CAK)
Pre-shared Key (CAK)
CKN Exchange and ICV Validation
Distributed SAK
SAK
SAK installed
SAK
MACsec protected traffic

Firewall

Firewall serves as an additional security layer to

- isolate/separate in-vehicle traffic (e.g. enforcing VLANs)
- block illegitimate communication to individual ECUs or the entire network
- control access to the in-vehicle network (OBD, charging stations, .)
- protect against DoS attacks
- support in detecting intruders



AUTOSAR firewall standardization

- Focus on host-based firewall
- Network firewalls on switches not in standardization scope
- Network firewall configuration possible by using AUTOSAR standardized firewall rule format

Firewall

The firewall allows network inspection on different layers

- **Stateless filters:** Inspect fields and check for allowed values
- **Stateful filters:** Inspect fields of stateful protocols and protect against attacks on the state machine (e.g. SYN-ACK flood)
- **Deep packet inspection (DPI):** Inspect fields of application-level protocols

Protocol	Category
Ethernet	Stateless
IPv4/v6	Stateless
UDP	Stateless
TSN	Stateless
ARP, NDP	Stateful
TCP	Stateful
ICMP v4/v6	Stateful
SOME/IP	DPI
SOME/IP SD	DPI
PDU	DPI
DoIP	DPI
DDS	DPI
Generic inspection	DPI

Planned features

- Standardized format for firewall filter rules
- Context-based filtering (based on vehicle state)
- Rate limiting
- Firewall as IDS Sensor

Planned release date: R22-11 for Adaptive, R23-11 for Classic

Firewall filter rule

SOME/IP

ETH
- Source MAC
- Destination MAC
- EtherType

IPv4
- Source IP Address
- Destination IP Address
- Version
- Flags
- Protocol

TCP
- State Management based on TCP flags (as per RFC 793)

SOME/IP
- Service ID
- Method ID
- Client ID

Generic inspection
- [(Offset, Data), (Offset, Data), 2Ilset, Data) . @

Action
- Alert
- Rate limit
- Vehicle state

ICMP

ETH
- Destination MAC

IPv4
- Destination IP Address

ICMP
- Type
- Code
- Checksum

Action
- Alert
- Rate limit
- Vehicle state

TSN

ETH
- Destination MAC

TSN
- (g)PTP - MessageType
- (g)PTP - DomainNumber
- (g)PTP - SourcePortIdentity

Action
- Alert
- Rate limit
- Vehicle state

AUTOSAR Security

How to secure the vehicle?

1. Harden ECUs

   Trusted Platform, Identity & Access Management

2. Secure in-vehicle communication

   SecOC, TLS, IPSec, Crypto-Stack

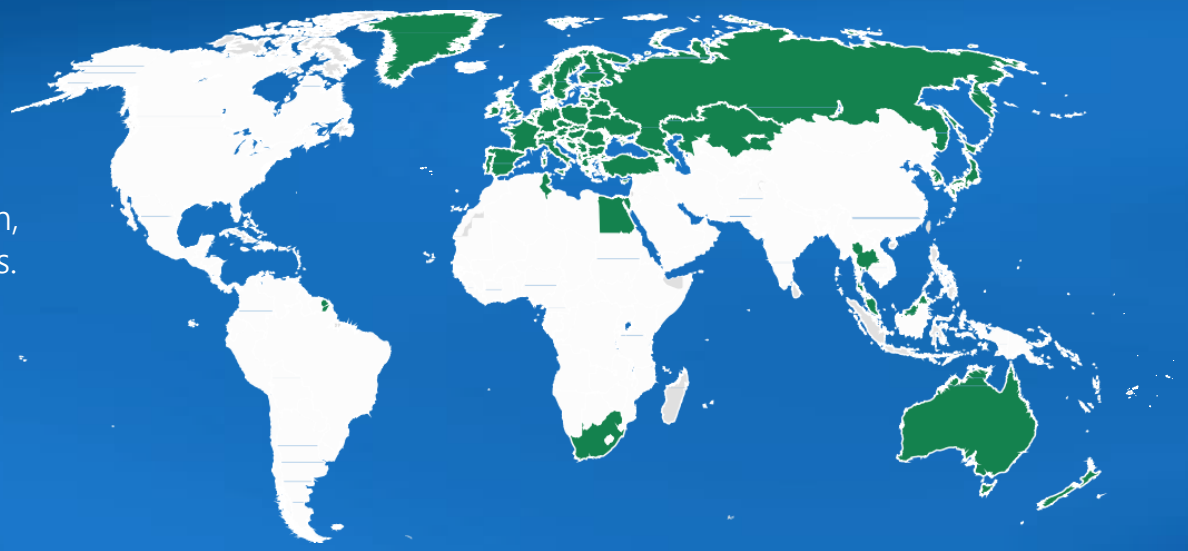
   Upcoming: MACSec, Firewall

3. Keep vehicle secure on the road

   IdsM, SOTA

UNECE

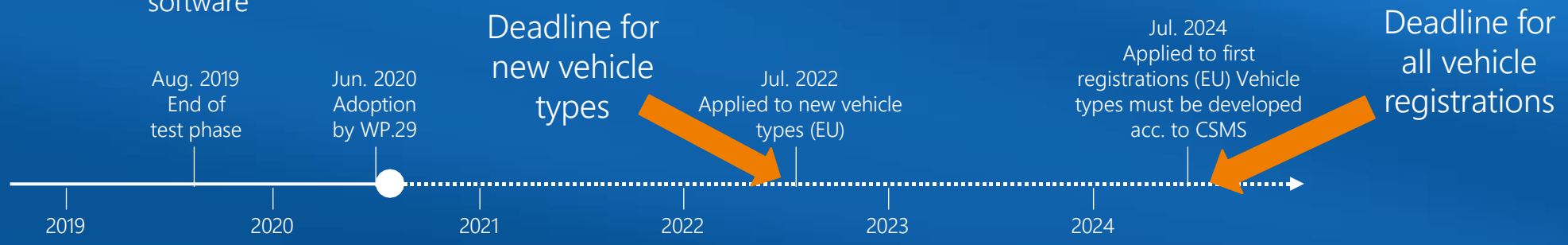
UNECE Regulations UN R155 and R156



The automotive sector is undergoing a profound transformation with the digitalization of in-car systems that are necessary to deliver vehicle automation, connectivity and shared mobility. This comes with significant cybersecurity risks.

The two new UN Regulations require that measures be implemented across **4 distinct disciplines** to tackle these risks by establishing clear performance and audit requirements for car manufacturers:

1) Managing vehicle cyber security
2) **Securing vehicles by design to mitigate risks along the value chain**
3) Detecting and responding to security incidents across vehicle fleet
4) Providing safe and secure software updates and ensuring vehicle safety is not compromised, introducing a legal basis for O.T.A. updates to on-board vehicle software



AUTOSAR Security Overview

Mapping of proposed mitigations to AUTOSAR security building blocks - AUTOSAR-UNECE security matrix

Measures to be taken into account according to Annex 5 of UN Regulation No. 155	Crypto stack	Secure communi-cation	Secure diagnostics/ logging	Identity & access mgmt.	Intrusion detection system	Secure updates	Trusted platform
M3 Security controls shall be applied to back-end systems. Where back-end servers are critical to the provision of services, there are recovery measures in case of system outage.	AUTOSAR the scope of the AUTOSAR application - mitigates threats AUTOSAR the vehicle						
M6 Systems shall implement security by design to minimize risks.	•	•	•	•	•	•	•
M7 Access control techniques and designs shall be applied to protect system data/code.			•	•			
M8 Through system design and access control, it should not be possible for unauthorized personnel to access personal or system-critical data.			•	•			
M9 Measures shall be employed to prevent and detect unauthorized access.				••	•		
M10 The vehicle shall verify the authenticity and integrity of messages it receives.	•	••					
M11 Security controls shall be implemented for storing cryptographic keys.	•						
M12 Confidential data transmitted to or from the vehicle shall be protected.	•						
M13 Measures to detect and recover from a denial of service attack shall be employed.					•		
M14 Measures to protect systems against embedded viruses/malware should be considered.					•		•
M15 Measures to detect malicious internal messages or activity should be considered.		••		•	•		
M16 Secure software update procedures shall be employed.	•					••	
M18 Measures shall be implemented for defining and controlling user roles and access privileges, based on the principle of least access privilege.			•	•			
M19 Organizations shall ensure security procedures are defined and followed including logging of actions and access related to the management of the security functions.			•	•	•		
M20 Security controls shall be applied to systems that have remote access.	•			•			
M21 Software shall be security assessed, authenticated and integrity protected. security controls shall be applied to minimize the risk from third-party software that is intended or foreseeable to be hosted on the vehicle.				••			••
M22 Security controls shall be applied to external interfaces.	•	•	••*				
M23 Cybersecurity best practices for software and hardware development shall be followed.	Beyond the scope of application from a software perspective, but AUTOSAR offers guidelines on secure coding						
M24 Best practices for the protection of data integrity and confidentiality shall be followed for storing personal data.	•			(•)**			

Rating:
- • AUTOSAR provides features that can be used to implement mitigation as part of a broader concept
- •• AUTOSAR provides features that implement mitigation to a large extent

* Applies only to t hreat diagnostic inter aces)

** Roles/rights management through IAM planned but not yet implemented

Internal

THANK YOU!

Legislations and Standards - Relevant Requirements from UN R155

How does an IDPS help in fulfilling the requirements?

7.3.4

"The vehicle manufacturer shall implement measures for the vehicle type to:

(a) Detect and prevent cyber-attacks against vehicles of the vehicle type;
(b) Support the monitoring capability of the vehicle manufacturer with regards to detecting threats, vulnerabilities and cyber-attacks relevant to the vehicle type;
(c) Provide data forensic capability to enable analysis of attempted or successful cyber- attacks.

- Detect and monitor the attacks using in-vehicle IDS sensors combined with backend data aggregated in the VSOC
- Prevent and respond to the attacks using the expert knowledge in the VSOC to immediately find adequate responses (e.g., software updates)
- The aggregated data allows data forensic and the analysis of attempted of successful cyberattacks

[…] The mitigations implemented shall include all mitigations referred to in Annex 5, Part B and C which are relevant for the risks identified. However, if a mitigation referred to in Annex 5, Part B or C, is not relevant or not sufficient for the risk identified, the vehicle manufacturer shall ensure that another appropriate mitigation is implemented […].(7.3.4.)

Excerpt of threats in annex

- Malicious internal (e.g., CAN) messages
- Unauthorized deletion/manipulation of system event logs
- Denial of service, for example this may be triggered on the internal network by flooding a CAN bus
- …

IDPS is not explicitly required by R155, but the requirements are hard to fulfill without

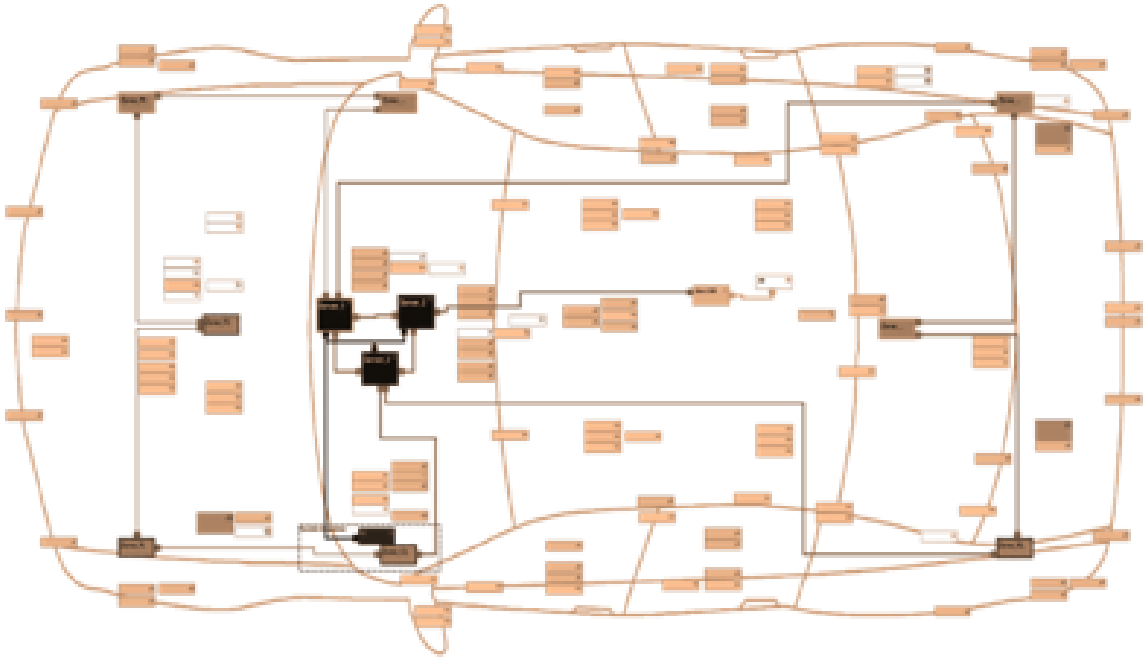
USE-CASES

- Firewall use-cases applicable on:
  - Vehicle computer/server
  - Ethernet Switch
  - End ECUs for applications like EV charging
- Network IDS use-cases applicable on:
  - Vehicle computer/server
  - Domain controllers
  - End ECUs
- IDS Manager use-cases applicable on:
  - Vehicle computer/server
  - Domain controller
  - End ECU
- IDS reporter use-case applicable on:
  - Vehicle computer/server

IDS-M collects, aggregates, and persist the security events

IDS-R reports the security events to the VSOC

IDS for CAN and Ethernet



µCs with classic AUTOSAR or RTOS

µPs running adaptive AUTOSAR and/or some POSIX OS

Firewall for Ethernet